1. Цель и область действия

Регламентирует порядок создания, изменения, блокировки и удаления учётных записей пользователей КТК, а также правила аутентификации и авторизации.

2. Ролевая модель (RBAC)

На основе анализа бизнес-процессов выделены следующие роли:

Роль	Разрешённые действия	Запрещённые действия
Обучаемый	Запуск сценариев, просмотр своих результатов	Изменение конфигурации, доступ к чужим данным
Инструктор	Создание/редактирование сценариев, назначение тренировок, просмотр всех результатов, формирование отчётов	Изменение системных настроек, доступ к моделям ИИ
Администратор	Управление пользователями, техобслуживание, обновление ПО, просмотр технических логов	Изменение результатов обучения, доступ к персональным данным без служебной необходимости
Аудитор	Чтение журналов аудита, подготовка отчётов по безопасности	Любые изменения в системе
Разработчик сценариев	Создание сценариев, доступ к математическим моделям	Доступ к персональным данным и результатам обучения

3. Правила создания учётных записей

- Запись создаётся на основании служебной записки, подписанной руководителем подразделения.
- Каждому пользователю назначается уникальный логин (формат: фамилия.инициалы).
- Первичный пароль генерируется автоматически и выдаётся пользователю в запечатанном конверте.

4. Требования к паролям

- Минимальная длина – 12 символов.
- Сложность: заглавные, строчные буквы, цифры, спецсимволы.
- Смена пароля – не реже 1 раза в 90 дней.
- Запрет на использование предыдущих 5 паролей.
- Блокировка учётной записи после 5 неудачных попыток входа на 15 минут.

5. Многофакторная аутентификация (MFA)

Для ролей «Инструктор», «Администратор», «Аудитор», «Разработчик сценариев» обязательна MFA с использованием аппаратных токенов или биометрии. Для «Обучаемого» допускается только парольная защита.

6. Управление сессиями

- Тайм-аут неактивности – 15 минут.
- Завершение сессии при закрытии браузера.
- Одновременная работа с одной учётной записью только с одного устройства.

7. Порядок блокировки доступа

- При увольнении – немедленно.
- При длительной командировке (более 30 дней) – по заявке.
- При подозрении на компрометацию – в течение 1 часа с момента выявления.

8. Журналирование

Все события входа/выхода, изменения прав и неудачные аутентификации фиксируются в центральном журнале аудита с хранением не менее 1 года.